Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

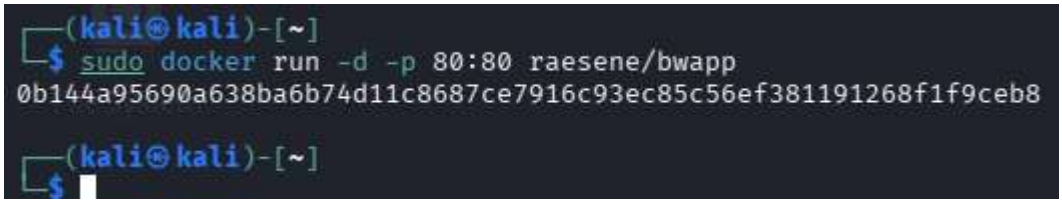
Sprawozdanie

Bezpieczeństwo aplikacji internetowych

Laboratorium nr 11

ZADANIE 2

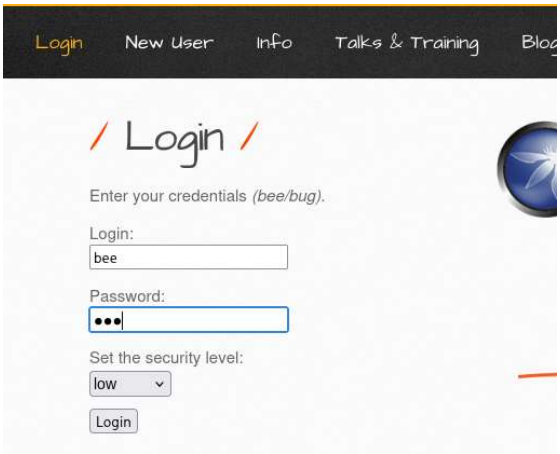
Uruchamiamy kontener bwapp.



ZADANIE 3

Instalujemy aplikację bWAPP a następnie logujemy się do niej na poziomie zabezpieczeń „low”.





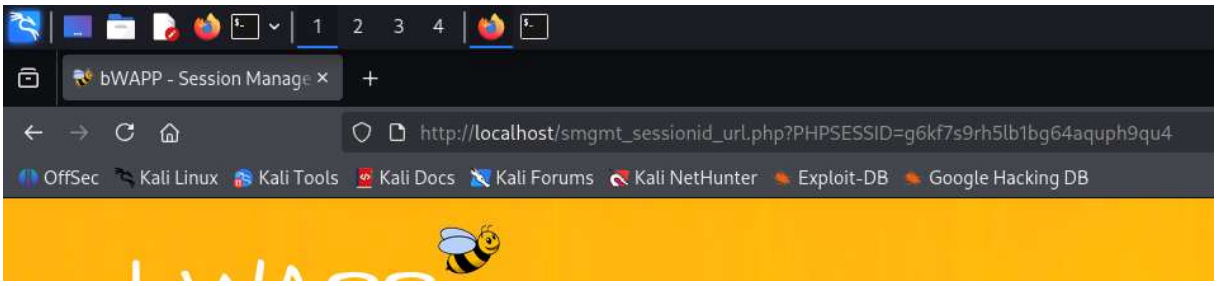
ZADANIE 4

Podatność – Ekspozycja SessionID w URL

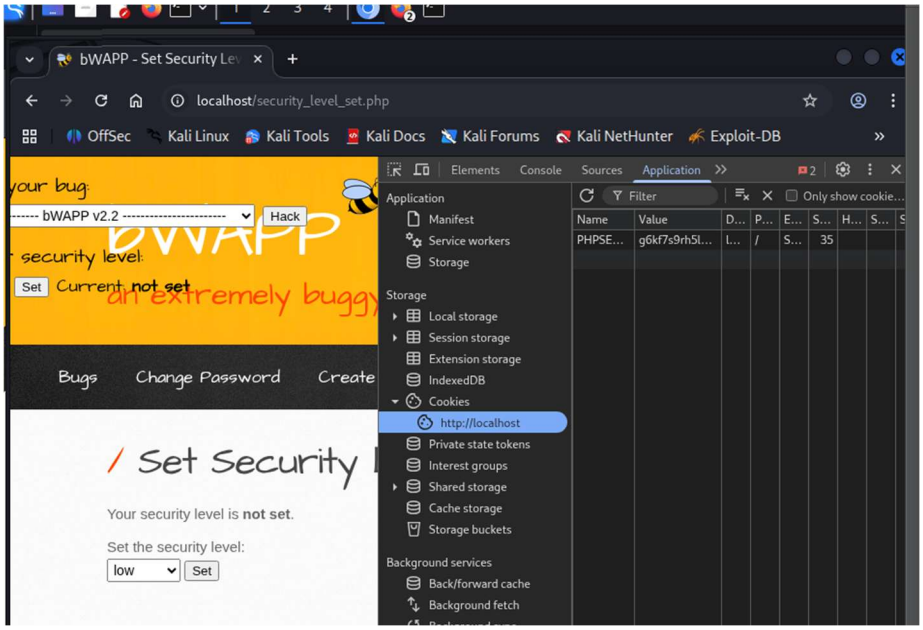
Podatność polega na przekazywaniu identyfikatora sesji w tym przypadku parametru PHPSESSID w adresie URL przy użyciu metody GET.

Proponowany scenariusz ataku - Przechwycenie sesji z wykorzystaniem aktywnego identyfikatora sesji ofiary:

1. Ofiara loguje się do aplikacji bWAPP. Serwer generuje unikalny token i umieszcza go w URL.

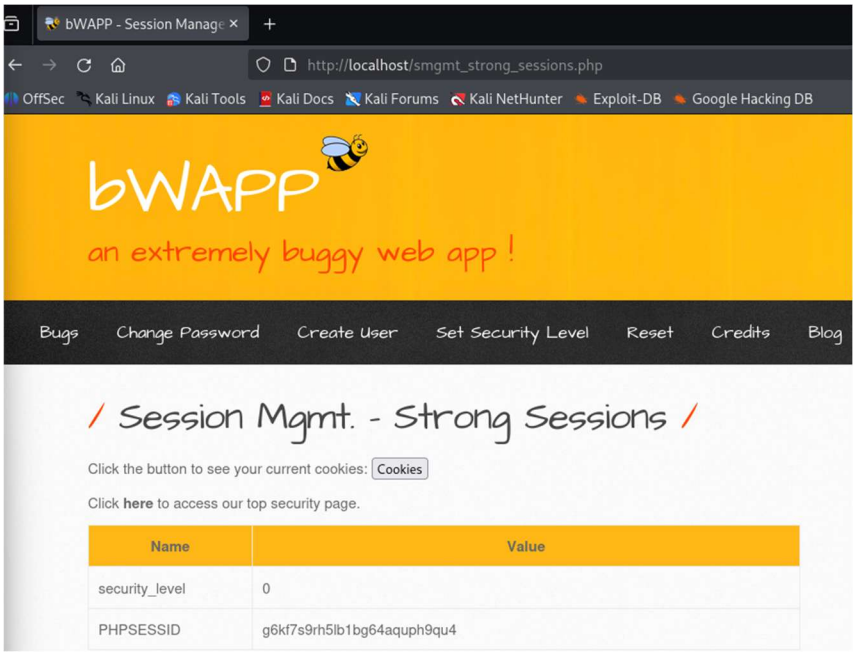


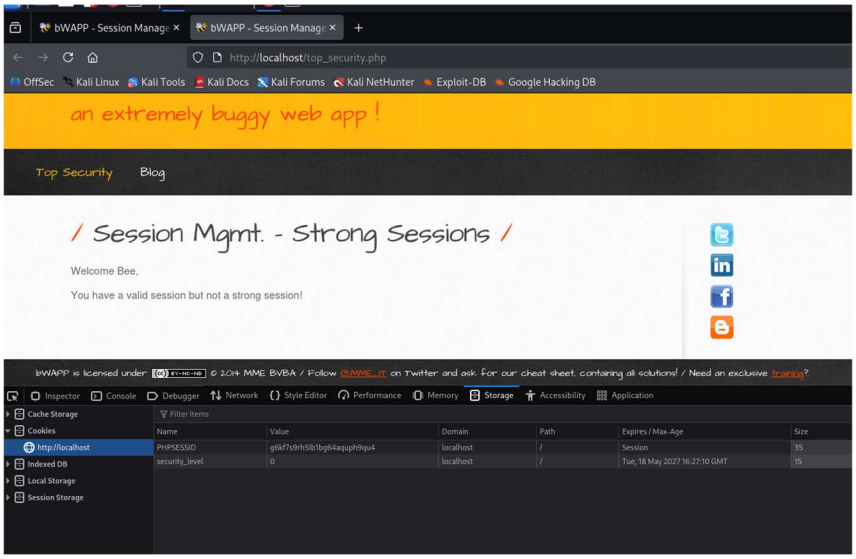
2. Ofiara znajduje w systemie raport lub stronę i chce ją komuś pokazać. Ofiara kopiuje cały adres URL z paska przeglądarki i wysyła go atakującemu za pomocą np. e-mailu.
3. Atakujący odbiera wiadomość i klika w otrzymany link lub wkleja go do swojej przeglądarki co skutkujemy tym, że przeglądarka atakującego wysyła żądanie do serwera bWAPP, dołączając w parametrze GET identyfikator sesji ofiary. Serwer bWAPP weryfikuje ten identyfikator, uznaje go za wciąż aktywny i przypisany do konta ofiary. W rezultacie atakujący zostaje zalogowany na konto ofiary bez konieczności podawania loginu i hasła. W teorii tak powinno to działać a w naszym przypadku należy jeszcze ręcznie przekleić wartość SESSIONID do odpowiedniego pola w zakładce cookies.



ZADANIE 5

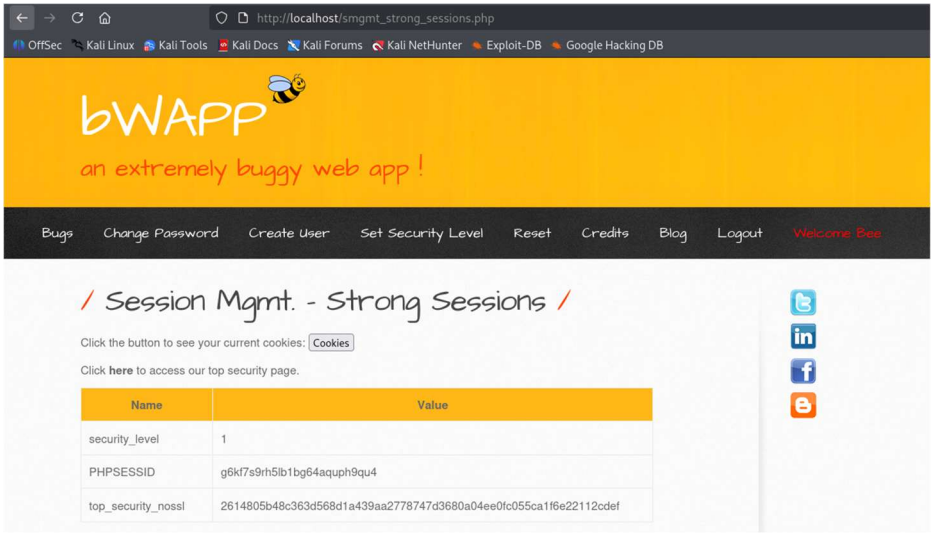
Poziom „Low”

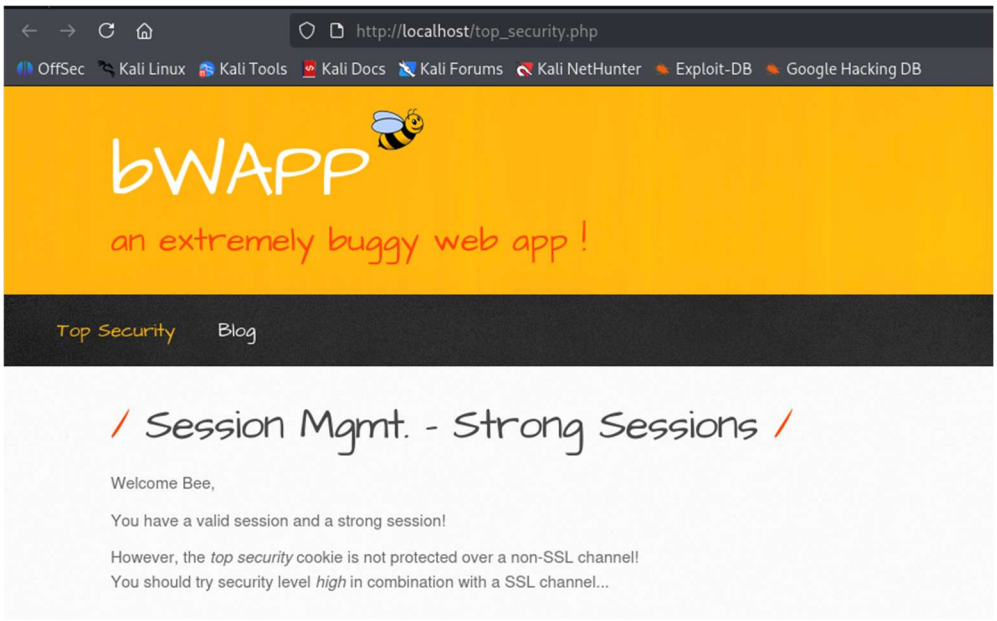




Na tym poziomie bWapp sprawdza nasze uprawnienia bez generowania dodatkowego tokenu aplikacja.

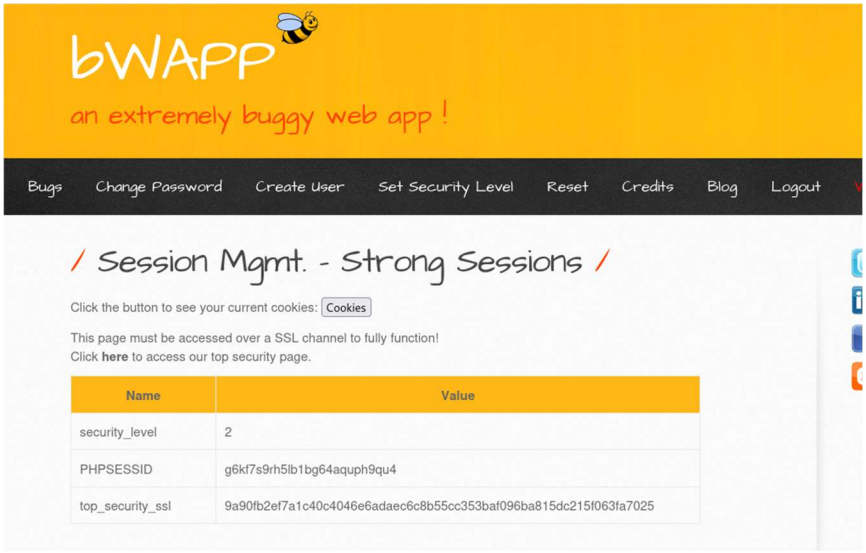
Poziom „Medium”

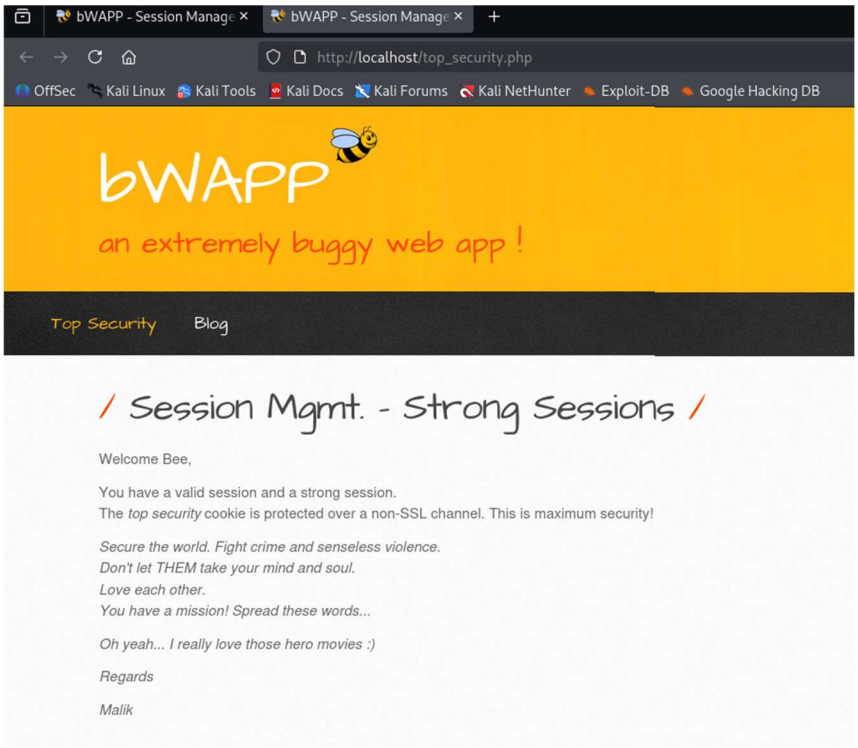




Przejście na wyższy poziom zaskutkowało wygenerowaniem tokenu. Aplikacja jednak ostrzega, że ciasteczka wciąż przesyłane są nieszyfrowanym kanałem.

Poziom „High”





Na poziomie High aplikacja wdraża maksymalne zabezpieczenie sesji. Choć bWapp wiąż informuje o braku szyfrowania SSL to sam token został wygenerowany przy użyciu silnego, losowego algorytmu co uniemożliwia jego przewidzenia.

ZADANIE 6

Usuwamy kontener

